Notas GDPR Básico - 27 Enero 2026

PII que identifico en sistemas comunes:

- [Nombre y apellido, edad, fecha de nacimiento, lugar de nacimiento, lugar de residencia, historial, IBAN, IP, comportamiento en la web, cookies, ubicacion, religion, etnia, clase social]

Principio Consentimiento:

- *¿Qué significa "explícito"?*

Significa que las solicitudes de consentimiento deben ser "claramente distinguibles de los demás asuntos" y presentarse en "lenguaje claro y claro".

- *¿Cómo NO hacerlo?*

En el caso que no se muestren, que no sean claras, o que esten sujetas a que sea necesarias si o si, ya que el consentimiento debe ser "dado libremente, específico, informado e inequívoco."

- *¿Cómo SÍ hacerlo?*

El consentimiento debe darse mediante un acto afirmativo claro que establezca una indicación libre, específica, informada y sin ambigüedades del acuerdo del sujeto de datos para el tratamiento de datos personales relacionados con él o ella, como mediante una declaración escrita, incluyendo medios electrónicos, o una declaración oral. Esto puede incluir marcar una casilla al visitar un sitio web, elegir configuraciones técnicas para los servicios de la sociedad de la información u otra declaración u conducta que indique claramente en este contexto la aceptación por parte del sujeto del tratamiento propuesto de sus datos personales. Por tanto, el silencio, las casillas marcadas previamente o la inactividad no deberían constituir consentimiento. El consentimiento debe abarcar todas las actividades de procesamiento realizadas con el mismo propósito o fines. Cuando el procesamiento tiene múltiples propósitos, se debe dar consentimiento para todos ellos. Si el consentimiento del usuario debe darse tras una solicitud por medios electrónicos, la solicitud debe ser clara, concisa y no innecesariamente disruptiva para el uso del servicio para el que se presta.Deberá tan fácil retirarse como dar su consentimiento. Para garantizar que el consentimiento se dé libremente, el consentimiento no debe proporcionar una base legal válida para el tratamiento de datos personales en un caso específico en el que exista un desequilibrio claro entre el sujeto de los datos y el responsable, en particular cuando el responsable es una autoridad pública y, por tanto, es poco probable que el consentimiento se haya dado libremente en todas las circunstancias de esa situación específica. Se presume que el consentimiento no se concede libremente si no permite conceder consentimiento separado a diferentes operaciones de tratamiento de datos personales, a pesar de que sea apropiado en el caso individual, o si la ejecución de un contrato, incluida la prestación de un servicio, depende del consentimiento a pesar de que dicho consentimiento no sea necesario para dicha ejecución.

Derecho al Olvido:

- *¿Qué significa técnicamente?*

-El sujeto de datos debe tener derecho a que se corrijan datos personales sobre él o ella y un 'derecho al olvido' cuando la conservación de dichos datos infrinja este Reglamento o la legislación de la Unión o del Estado Miembro al que esté sujeto el responsable. En particular, un persona en particular debe tener derecho a que sus datos personales sean borrados y no procesados cuando estos ya no sean necesarios en relación con los fines para los que se recopilan o se procesan, cuando el titular haya retirado su consentimiento o se oponga al tratamiento de datos personales que le concernen, o cuando el tratamiento de sus datos personales no cumpla con este Reglamento. Ese derecho es relevante especialmente cuando el sujeto ha dado su consentimiento siendo menor y no es plenamente consciente de los riesgos que conlleva el tratamiento, y posteriormente quiere eliminar dichos datos personales, especialmente en internet. El sujeto debe poder ejercer ese derecho a pesar de que ya no es un menor. Sin embargo, la retención adicional de los datos personales debe ser legal cuando sea necesario, para ejercer el derecho a la libertad de expresión e información, para el cumplimiento de una obligación legal, para el cumplimiento de una tarea realizada en interés público o para el ejercicio de la autoridad oficial conferida al responsable, por motivos de interés público en el ámbito de la salud pública, para fines de archivo en interés público, investigación científica o histórica o estadística, o para el establecimiento, ejercicio o defensa de reclamaciones legales.

- *¿Qué problemas arquitectónicos crea?*

El problema que crea, es que una vez que tenga esos datos PII, que hacer con ellos, si los almaceno, tengo que crear una arquitectura para darles el tratamiento como es debido, dentro del margen de la ley.

Pregunta personal:

¿En cuántos sistemas he dado consentimiento sin leer?

En practicamente el 99.9% de las veces he dado consentimiento sin leer.

IMPLICACIONES ARQUITECTÓNICAS - Mi Traducción (SIN código)

Si mañana diseño un sistema que guarda usuarios:

Datos que guardaría:

- Email (para login)
- Nombre (para personalización)
- Fecha de registro

Problema #1: "Derecho al olvido" El usuario pide "elimina mis datos".

Opción A - Eliminar de verdad: ❌ Problema: Si tiene pedidos, facturas, historial → todo se rompe ❌ Si necesito data para impuestos → ilegal eliminarlo (retención obligatoria)

Opción B - "Marcar como eliminado" (pero no borrar): ☑ Guardo: "Usuario eliminado en 27/01/2026" ☑ Ya no aparece en búsquedas ☑ Pero datos siguen ahí (para legal, auditorías) ☑ Email/nombre se reemplazan por "USUARIO_ELIMINADO_12345"

Pregunta arquitectónica: ¿Qué diseño elijo? Depende de:

- ¿Qué datos son legalmente obligatorios guardar? (facturas 10 años)
- ¿Qué datos puedo eliminar de verdad? (preferencias, historial navegación)

Problema #2: Servicios externos Si uso Google Analytics, Mailchimp, herramientas terceros:

- ¿Cómo elimino datos allá también?
- Debo mapear: "¿A dónde envío datos de usuarios?"

Problema #3: Logs y backups Si hago backup de mi base de datos cada día:

- ¿Cómo elimino de backups de hace 3 meses?
- Solución arquitectónica: Encriptar PII, eliminar "llave de encriptación" del usuario

Conclusión arquitectónica: "Derecho al olvido" NO es solo botón "delete". Es decisión de diseño que afecta:

- Cómo estructuro datos
- Qué guardo vs qué encripto
- Qué servicios externos uso
- Cómo hago backups